

Narrativa explicativa del marco GQM + PRAGMATIC sobre indicadores CVSS v4.0

1. El problema: del CVE al BOE

Durante años, los equipos de ciberseguridad han medido su mundo con números que sólo ellos entendían: 9.8 aquí, 7.5 allá, parches que “no se pueden aplicar” porque “rompen cosas”. [web:1][web:22] Mientras tanto, los responsables políticos tenían otros problemas: continuidad de servicios esenciales, sanciones europeas, portadas de periódicos. [web:7][web:12] La conversación era, en esencia, dos monólogos.

El marco GQM + PRAGMATIC intenta solucionar este divorcio estructural: los objetivos se formulan en términos de país, las preguntas se redactan en lenguaje inteligible y las métricas se construyen usando CVSS v4.0 como gramática técnica común. [web:1][web:16][web:26][web:27] Si lo hacemos bien, el mismo indicador sirve para un director de hospital, un ministro y un analista de vulnerabilidades, cada uno con su lectura, pero sin traducción simultánea ad hoc.

2. Por qué GQM es el pegamento

GQM no es una moda, es un método muy simple con una virtud peligrosa: obliga a justificar cada número con una pregunta y cada pregunta con un objetivo. [web:20][web:26][web:29] Traducido: prohíbe, de facto, los KPIs decorativos y obliga a admitir, negro sobre blanco, cuando una métrica existe “porque la herramienta lo da”.

Aplicado a CVSS v4.0, GQM nos obliga a decidir qué queremos lograr como país (menos incidentes en servicios esenciales, menos exposición a vulnerabilidades explotadas, mejor cumplimiento regulatorio), y sólo entonces pensar qué preguntas debemos responder y qué métricas CVSS nos ayudan a contestarlas. [web:1][web:7][web:13][web:22] El orden importa: empezar por la métrica es la receta clásica para dashboards vacíos.

3. El papel de PRAGMATIC: matar métricas zombies

PRAGMATIC es la parte cruel del marco: una batería de nueve criterios que evalúan la utilidad real de cada métrica. [web:21][web:24][web:27] Una métrica puede ser técnicamente perfecta y, sin embargo, irrelevante, poco accionable, imposible de mantener o cara de generar. En otras palabras: un zombie que consume recursos y no aporta decisiones.

Al puntuar los indicadores CVSS nacionales con PRAGMATIC, aceptamos que la belleza técnica no basta. [web:21][web:24] Lo que buscamos son métricas que anticipen problemas, importen a los decisores, sugieran acciones claras, resistan la manipulación, se entiendan fuera del nicho, se calculen con datos decentes, lleguen a tiempo, no se autojustifiquen y no exijan un presupuesto del CERN para mantenerse.

4. CVSS v4.0 como “idioma base”

CVSS v4.0 es, a la vez, más preciso y más incómodo que sus predecesores: fuerza a distinguir entre severidad intrínseca (Base), amenaza real (Threat), contexto de despliegue (Environmental) y atributos

específicos como impacto en la vida humana o en productos de seguridad (Supplemental). [web:1][web:16][web:22][web:18] Esa incomodidad es una virtud: impide esconder decisiones políticas detrás de un único número mágico.

En un contexto nacional, esto se traduce en indicadores que reconocen que una misma vulnerabilidad no significa lo mismo en un servidor de pruebas que en un sistema de emergencias sanitarias, aunque compartan CVSS Base. [web:1][web:10][web:12] La métrica deja de ser un dictado de un fabricante remoto y pasa a ser una decisión informada sobre qué nos puede hundir un país en pleno puente de agosto.

5. España, Europa y el nuevo ecosistema de vulnerabilidades

NIS2, ENISA y la European Vulnerability Database marcan un camino bastante claro: el tratamiento de vulnerabilidades es ya una cuestión de política pública, no sólo de higiene técnica. [web:7][web:13] España, con sus estrategias digitales y de ciberseguridad, no puede permitirse métricas artesanales que no casen con este entorno; necesita un sistema de indicadores que se entusiasme tanto con CVSS como con el BOE. [web:6][web:9][web:12]

El marco GQM + PRAGMATIC que aquí se propone está pensado para encajar con las obligaciones de reporte europeo, los intereses de los ministerios y la realidad de los operadores críticos. [web:7][web:13][web:12] El tono puede ser irónico; la arquitectura, por fuerza, debe ser extremadamente sobria.

6. Cómo leer este kit

Este kit no es una colección de tablas para llenar a las tres de la mañana antes de una auditoría. Es una invitación a cambiar la conversación sobre métricas de vulnerabilidades en clave país.

- Si eres regulador, te interesará que las métricas con mejor puntuación PRAGMATIC entren en tus guías y plantillas.
- Si diriges un CSIRT sectorial, usarás el marco para justificar por qué mides unas cosas y no otras.
- Si estás en una CCAA, te dará un lenguaje común para comparar tu exposición con la media nacional sin caer en la tentación de “nuestro caso es único”.

Y si nada de esto te convence, al menos habrás ordenado tu colección de métricas, lo cual ya es más de lo que puede decirse de muchos dashboards.